

Security+ 2.4 · Spyware & Bloatware

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4** —
Spyware & Bloatware (4:21) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Spyware covertly collects user information without consent, including tracking behavior and software keyloggers. Bloatware is pre-installed, unnecessary software that expands the attack surface. Adware displays unwanted advertisements. PUP (Potentially Unwanted Program) is not necessarily malicious but was not requested by the user. Defenses include antivirus with anti-spyware capabilities, strict installation policies, and reviewing app permissions.

High-Yield Core Concepts Tested on Exam

- Spyware collects data (including passwords) WITHOUT authorization; bloatware is useless pre-installed software
- PUP (Potentially Unwanted Program) is not malware, but the user did NOT request it
- Adware delivers unwanted advertisements and may track browsing habits
- Defense: antivirus with anti-spyware, application installation policies, permission auditing

Exam Tips & Classic Scenarios

- 'tracks user behavior without consent' = spyware
- 'pre-installed software that is not needed' = bloatware
- 'unwanted program that is not malicious' = PUP

Typical Exam Scenario: Scenario: 'An installed application collects browser passwords without the user's knowledge' = spyware.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Spyware & Bloatware)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **WORM:** Write Once, Read Many: Immutable optical/cloud storage paradigm preventing data alteration or deletion during retention periods (critical for audit logs).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Malware that encrypts your files and demands payment to return them is:

- A) Spyware
- B) Ransomware
- C) Rootkit
- D) Worm

2. The NIST CSF framework organizes security into 5 functions. What are they?

- A) Install, Update, Test, Audit, Archive
- B) Identify, Protect, Detect, Respond, Recover
- C) Plan, Do, Check, Act, Review
- D) Prevent, Punish, Predict, Prove, Publish

3. Corporate scenario (Spyware & Bloatware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Spyware: collects PASSWORD WITHOUT authorization; bloatware: pre-installed useless'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Spyware: collects PASSWORD WITHOUT authorization; bloatware: pre-installed useless...

4. Corporate scenario (Spyware & Bloatware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'PUP (Potentially Unwanted) 'is not malware, but you did NOT ask for it''. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: PUP (Potentially Unwanted) 'is not malware, but you did NOT ask for it'...

5. Corporate scenario (Spyware & Bloatware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: '"tracks user behaviour without consent' = spyware'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'tracks user behaviour without consent' = spyware...
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Spyware & Bloatware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: 'installed application that collects browser passwords without the user's knowledge' = spyware.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: 'installed application that collects browser passwords without the user's knowledge' = spyware...
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Spyware & Bloatware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Spyware: collects PASSWORD WITHOUT authorization; bloatware: pre-installed useless'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Spyware: collects PASSWORD WITHOUT authorization; bloatware: pre-installed useless...

8. Corporate scenario (Spyware & Bloatware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'PUP (Potentially Unwanted) 'is not malware, but you did NOT ask for it''. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: PUP (Potentially Unwanted) 'is not malware, but you did NOT ask for it'...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Spyware & Bloatware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'tracks user behaviour without consent' = spyware'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'tracks user behaviour without consent' = spyware...
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Spyware & Bloatware): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: Scenario: 'installed application that collects browser password without the user's knowledge' = spyware. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: 'installed application that collects browser password without the user's knowledge' = spyware...
- D)** Allow shared access among administrators with generic credentials



COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Ransomware.

✓ **Why it is correct:** The correct answer is 'Ransomware'. Ransomware is a type of malware that encrypts the victim's files and demands a ransom payment (usually in cryptocurrency) to provide the decryption key. The statement describes exactly this behavior: malware that encrypts files and demands payment to return them. CompTIA classifies ransomware as a critical threat, often propagated through phishing, vulnerability exploitation, or remote desktop services. Therefore, the option 'Ransomware' is the precise definition of the described attack.

✗ **Why the other options are wrong:**

- *Spyware*: Spyware is malicious software designed to collect information from the infected system without the user's consent, such as browsing habits, credentials, banking data, etc. It does not encrypt files or demand ransom. Its primary function is to spy and exfiltrate data. In the scenario, the goal is to extort money through file encryption, which is not a characteristic of spyware. Therefore, spyware does not apply.
- *Rootkit*: A rootkit is a set of malicious tools that allows an attacker to gain privileged access (root) and maintain persistence on the system, hiding its presence from detection mechanisms. Although it can be used in conjunction with ransomware, a rootkit itself does not encrypt files or demand payment. Its purpose is stealth, not extortion. The statement describes a financial extortion attack via encryption, not the installation of a rootkit. Thus, rootkit is not the correct answer.
- *Worm*: A worm is self-replicating malware that spreads automatically across the network, exploiting vulnerabilities, without necessarily needing a host file or user interaction. Although worms can carry payloads like ransomware, they are not defined by encrypting files and demanding ransom. The behavior described in the statement is specific to ransomware, not a worm. Therefore, worm is an incorrect classification for the attack in question.

2) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive*: These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review*: This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a

distortion, as the classic PDCA has four steps.

- *Prevent, Punish, Predict, Prove, Publish*: These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

3) D — Implement the corresponding solution: Spyware: collects PASSWORD WITHOUT authorization; bloatware: pre-installed useless....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Spyware & Bloatware): Spyware: collects PASSWORD WITHOUT authorization; bloatware: pre-installed useless. Spyware is malware that secretly gathers user information, including credentials, without consent, while bloatware is unwanted pre-installed software that consumes resources but is not malicious per se.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) D — Implement the corresponding solution: PUP (Potentially Unwanted) 'is not malware, but you did NOT ask for it'....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Spyware & Bloatware): PUP (Potentially Unwanted) 'is not malware, but you did NOT ask for it'.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) C — Implement the corresponding solution: 'tracks user behaviour without consent' = spyware....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Spyware & Bloatware): 'tracks user behaviour without consent' = spyware. Spyware is malicious software that secretly monitors and collects user activity, keystrokes, or personal information without the user's knowledge or consent. It is a significant privacy and security threat.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Scenario: 'installed application that collects browser passwords without the user's knowledge' = spyware....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Spyware & Bloatware): Scenario: 'installed application that collects browser passwords without the user's knowledge' = spyware.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: Spyware: collects PASSWORD WITHOUT authorization; bloatware: pre-installed useless....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Spyware & Bloatware): Spyware: collects PASSWORD WITHOUT authorization; bloatware: pre-installed useless. This accurately distinguishes spyware (malicious data collection) from bloatware (unnecessary pre-installed software).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: PUP (Potentially Unwanted) 'is not malware, but you did NOT ask for it'....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Spyware & Bloatware): PUP (Potentially Unwanted) 'is not malware, but you did NOT ask for it'. PUPs are programs that may not be malicious but are unwanted, often bundled with

other software and can degrade system performance or introduce privacy risks.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: 'tracks user behaviour without consent' = spyware....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Spyware & Bloatware): 'tracks user behaviour without consent' = spyware.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Scenario: 'installed application that collects browser password without the user's knowledge' = spyware....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Spyware & Bloatware): Scenario: 'installed application that collects browser password without the user's knowledge' = spyware.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

